RELATÓRIO TÉCNICO DE TESTE DE INTRUSÃO

Laboratório Metasploitable 2 e DVWA

Responsável Técnico	Roberto Oliveira de Jesus	**Data**	03/11/2026
Organização / Curso	Santander - Cibersegurança do Zero à Prática - DIO	**Versão**	1.1 (Atualizada)
Professora	Isadora Garcia Ferrão (PhD in Computer Science)	**Classificação**	CONFIDENCIAL

1. Sumário Executivo

Foi realizada uma avaliação de segurança controlada no ativo `192.168.0.15`, correspondente ao ambiente de laboratório Metasploitable 2, contemplando serviços de infraestrutura de rede e a aplicação web vulnerável **DVWA (Damn Vulnerable Web Application)**.

A varredura inicial revelou a exposição de **23 portas TCP abertas**, demonstrando uma superfície de ataque extensa. Foram comprovadas autenticações bem-sucedidas com a credencial padrão/fraca `msfadmin` nos serviços SSH, FTP e SMB. Adicionalmente, na aplicação web DVWA, foi validada a autenticação administrativa via requisições automatizadas com Medusa e confirmação visual de sessão ativa com privilégios elevados.

2. Objetivo e Escopo

Objetivo: Avaliar a segurança dos mecanismos de autenticação e serviços expostos no laboratório, documentar evidências reprodutíveis, identificar vulnerabilidades e propor medidas de correção e mitigação.

Escopo: Endereço IP `192.168.0.15` (Rede interna de testes). Serviços avaliados: SSH (22/tcp), FTP (21/tcp), SMB (139, 445/tcp) e HTTP/DVWA (80/tcp).

3. Metodologia

As atividades seguiram as fases convencionais de um teste de intrusão ético:

- **Reconhecimento e Descoberta:** Mapeamento de ativos (`nmap -sn`) e varredura de portas e versões (`nmap -sV`).
- **Auditoria de Credenciais:** Ataques de força bruta e password spraying automatizados utilizando a ferramenta **Medusa**.
- **Validação de Acesso:** Confirmação manual de login interativo e acesso a serviços (SSH, FTP, SMB e Navegador Web).
- **Documentação e Análise de Risco:** Registro de evidências e formulação de recomendações de mitigação.

4. Reconhecimento e Enumeração

4.1 Descoberta de Hosts

O comando `nmap -sn 192.168.0.15/24` identificou múltiplos ativos na sub-rede (192.168.0.1, .2, .3, .15, .16, .47, .51). O alvo isolado e validado para a execução dos testes foi o endereço `192.168.0.15` (VirtualBox Virtual NIC).

4.2 Serviços Identificados

A varredura de versões (`nmap -sV 192.168.0.15`) identificou 23 portas abertas. Destaques do inventário:

Porta / Protocolo	Serviço	Versão Detectada	Observação Técnica
21/tcp	FTP	vsftpd 2.3.4	Serviço de transferência sem criptografia
22/tcp	SSH	OpenSSH 4.7p1 Debian	Acesso a terminal remoto
80/tcp	HTTP	Apache httpd 2.2.8	Hospeda a aplicação DVWA
139 / 445/tcp	SMB	Samba smbd 3.0.20-Debian	Compartilhamento de arquivos em rede

5. Resultados de Auditoria de Credenciais (Serviços de Infraestrutura)

5.1 SSH (Porta 22)

A ferramenta Medusa identificou a credencial `msfadmin : msfadmin`. A validação manual via comando `ssh msfadmin@192.168.0.15` estabeleceu sessão remota com sucesso, obtendo o prompt `msfadmin@metasploitable:~$`.

5.2 FTP (Porta 21)

A auditoria via Medusa reportou sucesso com `msfadmin : msfadmin`. O login manual via cliente FTP retornou `230 Login successful`, permitindo a listagem do diretório remoto `vulnerable`.

5.3 SMB (Portas 139/445)

O Medusa retornou `SUCCESS (ADMIN$ - Access Allowed)` com as credenciais de `msfadmin`. O utilitário `smbclient -L //192.168.0.15 -U msfadmin` mapeou os compartilhamentos `print$`, `tmp`, `opt`, `IPC$`, `ADMIN$` e `msfadmin`.

6. Avaliação da Aplicação Web DVWA

A auditoria focou no formulário de autenticação da aplicação web DVWA (`http://192.168.0.15/dvwa/login.php`).

6.1 Auditoria Automatizada com Medusa (Módulo HTTP)

Durante a execução da automação contra o formulário web, a ferramenta Medusa reportou três combinações válidas de credenciais (`ACCOUNT FOUND`):

```
ACCOUNT FOUND: [web-form] Host: 192.168.0.15 User: admin Password: password [SUCCESS] ACCOUNT
FOUND: [web-form] Host: 192.168.0.15 User: password Password: password [SUCCESS] ACCOUNT FOUN
D: [web-form] Host: 192.168.0.15 User: msfadmin Password: password [SUCCESS]
```

> **Análise Técnica do Comando e Sintaxe:**
> Foram observadas mensagens de erro no terminal do operador como `-m: command not found`. Isso ocorre quando quebras de linha em comandos multilinhas são coladas incorretamente no terminal Linux, fazendo com que os parâmetros subsequentes sejam interpretados como comandos inexistentes. Apesar desta falha de interpretação sintática no terminal, a execução parcial do Medusa registrou com êxito os resultados de autenticação reportados acima.

6.2 Validação Visual de Sessão Autenticada

A captura de tela fornecida (`https://lh3.googleusercontent.com/gg/AJWXcNe2y2lGwVR6AQIwpHQ8rkZyzyc4cs1iDUEtRAq4HCysiAk5GIO2dGK_tBRyOKs-rg3wG22zK1BBDqDTVdxZi7_4acqH7mvWWYOoYzxj5Tzi6tL3LlhoYvXnWM5paObvAZtvkn8pQmDTgwYjh00_RljDk3DRi64yGVJSGXTBy23pLvBNdLJS36s3pRDY4Q22Dv-QCqzTkobLVk3f6OkZFtz7gPtoFrvbb1eTz6dVmLB6YnVvM_L5_U6wCfHJYZ-7yeU0H3PYSpmWpWhUJz_4_-34vHdiUTuMXy8=s0`) comprova categoricamente o acesso bem-sucedido à interface interna do DVWA:

- **Usuário Autenticado:** `admin` (confirmado no rodapé do painel lateral).
- **Nível de Segurança (Security Level):** `high`.
- **Estado da Aplicação:** Acesso garantido ao painel principal "Welcome to Damn Vulnerable Web App!".

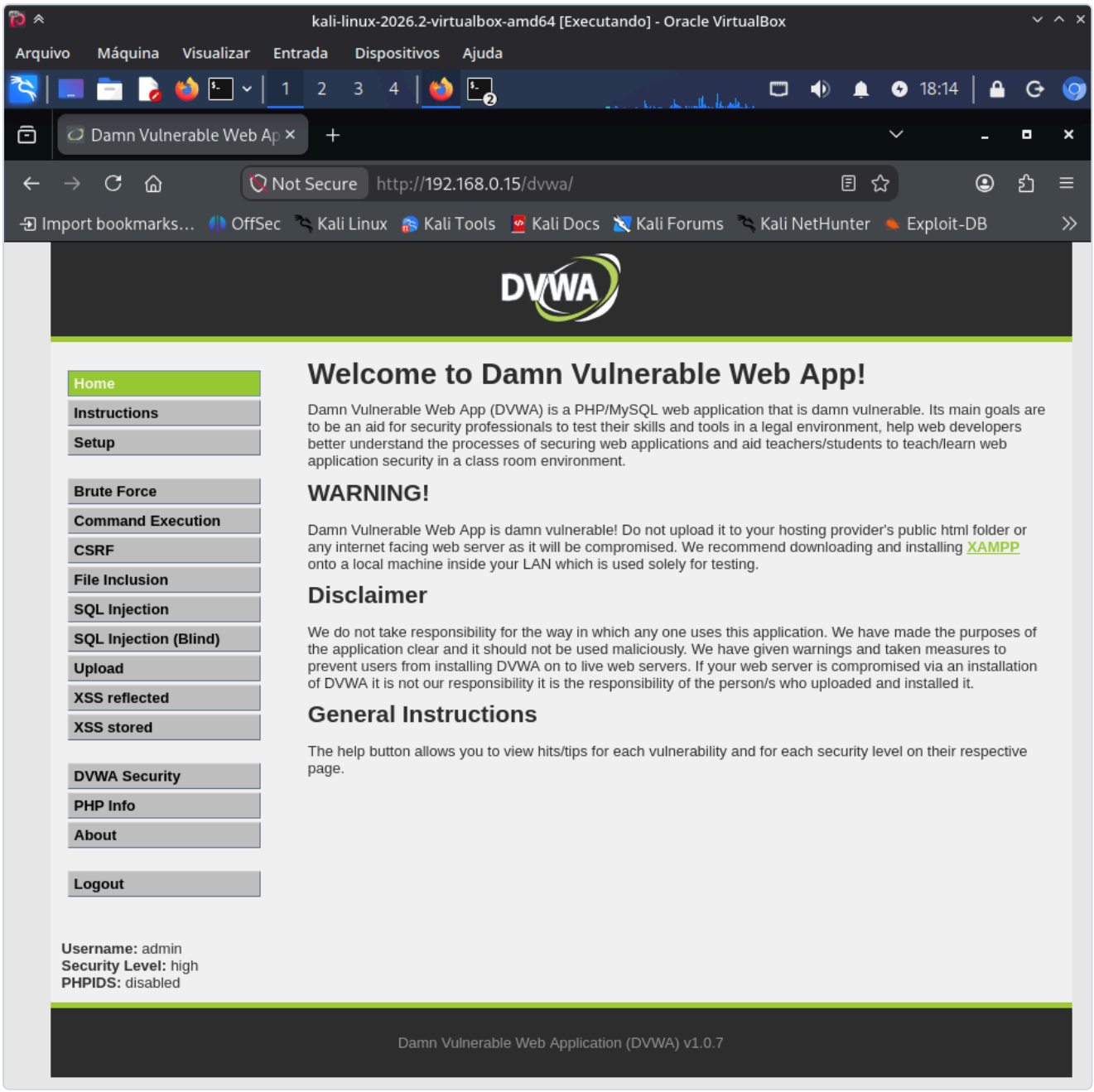


Figura 1: Evidência do painel DVWA acessado com usuário admin e nível de segurança high.

6.3 Observação sobre Resposta das Contas

Embora o Medusa tenha marcado SUCCESS para três usuários distintos (`admin`, `password` e `msfadmin`), a verificação visual no navegador valida formalmente a sessão ativa da conta `admin`. As demais contas reportadas pelo módulo automatizado devem ser tratadas como potenciais falsos positivos da ferramenta ou necessitam de validação individual de sessão HTTP.

7. Quadro de Vulnerabilidades e Achados

ID	Vulnerabilidade	Severidade	Descrição Sintética
VULN-01	Uso de Credenciais Padrão e Fracas	ALTA	Uso de senhas triviais (`msfadmin:msfadmin`, `admin:password`) em múltiplos serviços (SSH, FTP, SMB, Web).
VULN-02	Ausência de Proteção contra Força Bruta	ALTA	Ausência de bloqueio de conta ou limitação de taxa (rate limiting) permitindo ataques de dicionário ininterruptos.
VULN-03	Serviços Inseguros e Legados Expostos	MÉDIA	Protocolos sem criptografia ativa (FTP, Telnet) e serviços antigos (Samba 3.0.20, vsftpd 2.3.4) expostos na rede.

8. Recomendações de Mitigação e Defesa

- **Gestão de Credenciais:** Alterar imediatamente todas as senhas padrão do sistema operacional e de aplicações web. Adotar políticas de senhas fortes (mínimo de 12 caracteres, complexidade e rotação).
- **Mecanismos Anti-Brute Force:**
  - Implementar utilitários de bloqueio temporário por IP (ex: *Fail2ban*) para SSH, FTP e serviços de rede.
  - Inserir controles de CAPTCHA, bloqueio de conta e proteção contra password spraying no formulário de login do DVWA / aplicações web.
- **Endurecimento de Serviços (Hardening):** Desativar serviços não essenciais (Telnet, R-services) e substituir o FTP convencional por transferência segura via SFTP/SSH.
- **Atualização de Software:** Atualizar os componentes do servidor (Apache, Samba, PostgreSQL, MySQL) para versões suportadas e corrigidas contra vulnerabilidades conhecidas.
- **Segmentação e Firewall:** Restringir o acesso às portas de gerenciamento (SSH, SMB, bancos de dados) utilizando firewalls baseados em host ou regras de segmento de rede.

9. Conclusão

O teste de intrusão comprovou que a principal superfície de exposição do ambiente Metasploitable 2 e da aplicação DVWA reside no **uso de credenciais fracas e padrão** associado à falta de mecanismos de bloqueio contra ataques automatizados. A autenticação foi confirmada com êxito em serviços críticos de infraestrutura (SSH, FTP, SMB) e na camada web (DVWA), concedendo acesso às funções do sistema e da aplicação. A aplicação célere das recomendações de mitigação elevará significativamente a postura de segurança do ambiente.

10. Limitações e Ressalvas

Esta avaliação foi realizada estritamente em ambiente de laboratório controlado. A análise do DVWA baseou-se nos resultados de autenticação do Medusa e na evidência visual do estado da aplicação fornecida via captura de tela.

Responsável Técnico: Roberto Oliveira de Jesus
Assinatura: _____

Aprovado por: Isadora Garcia Ferrão
Data: 03/11/2026